

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 8 - Validating NTLM hash reuse for privileged access in the lab

Report Section	Phase 08 - Pass-the-Hash Validation
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **Pass-the-Hash Validation** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Validate whether NTLM hash material can authenticate to a Windows target without knowing the plaintext password, demonstrating why exposed hashes must be treated like credentials.

MITRE / Framework Mapping	T1550.002 - Use Alternate Authentication Material: Pass the Hash
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Use only lab-generated NTLM hash material.
- Run Impacket psexec-style authentication using hash material.
- Validate shell context using whoami.
- Do not upload raw hashes or command outputs containing real secrets.
- Document the result as Pass-the-Hash validation, not as malware or persistence.

Command / Workflow Used

```
# Example Impacket-style Pass-the-Hash workflow
psexec.py <DOMAIN>/<USER>@<TARGET_IP> -hashes :<REDACTED_NTLM_HASH>

# Validate shell context after access is obtained
whoami
```

Sanitized Output Style

```
Authentication material: <REDACTED_NTLM_HASH>
Target: <TARGET_IP>
Result: shell obtained in lab
Privilege check: nt authority\system
```

3. Evidence Mapping and Screenshot Explanation

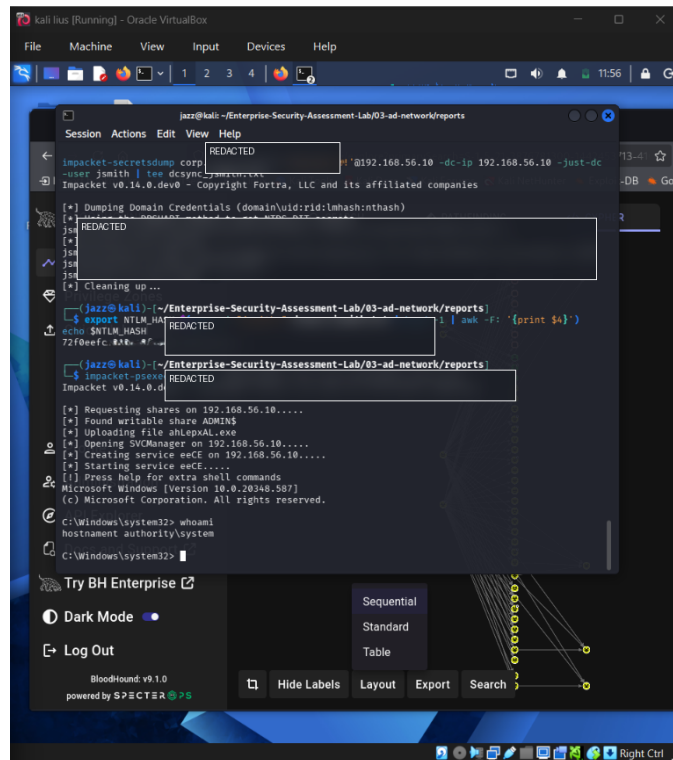


Figure - Pass-the-Hash validation resulting in SYSTEM shell

This screenshot shows Pass-the-Hash validation in the controlled lab and confirms privileged shell access. Sensitive hashes and command material are redacted.

4. Technical Interpretation

The evidence is interpreted in the context of a private AD lab. The screenshot proves execution of the relevant technique or validation step, while the sanitized command and output blocks show how the result should be presented without exposing raw credential material.

What the evidence proves	The lab phase for Pass-the-Hash Validation was executed and documented.
What it does not prove	It does not indicate testing of any public, third-party, or production network.
Publication status	Safe for GitHub after redaction of sensitive values.

5. Risk Analysis

NTLM hashes can sometimes be reused like passwords. If an attacker obtains a privileged NTLM hash, they may move laterally or gain administrative access without recovering the plaintext password.

Real-World Impact Categories

- Credential exposure or credential reuse risk
- Lateral movement or privilege escalation potential depending on account rights
- Domain visibility and attack path discovery in internal environments
- Operational and detection gaps if monitoring does not cover the relevant Windows, Kerberos, SMB, or LDAP events

6. Recommended Remediation

- Reduce NTLM usage where possible.
- Use Windows LAPS or Microsoft LAPS to prevent local admin password reuse.

- Enable Credential Guard where appropriate.
- Restrict lateral movement and administrative logons.
- Monitor remote service creation and privileged SMB/RPC access.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **Pass-the-Hash Validation** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.